ARCHITECTURE_REVIEW.md: Architecture Review Report

Basis: static review of seven exports + SQL. No runtime evidence.

Confirmed architecture

Seven workflows: two HTTP entry points (CT-01, CT-06), one schedule (CT-05), one error trigger (CT-04), three sub-workflows (CT-02 state/audit hub, CT-03 Slack dispatch, CT-07 HubSpot, currently unreachable). Supabase holds all state; all state changes route through CT-02.

Strengths

Single state writer with an explicit transition map; deterministic scoring ("AI assesses, code decides"); AI fallback with audit; schema-validated AI output plus clamping; duplicate guard; retry loop with backoff, exhaustion and human recovery; audit rows for nearly every transition; read-only CRM context; HTML escaping of notes; all workflow columns match the schema; all audit `status` values satisfy the CHECK.

Findings (ranked)

ID	Severity	Finding	Practical impact
F-01	CRITICAL	CT-06 `/ops-recover` has no authentication; `actor` is caller-supplied	Anyone reaching the URL can re-open ESCALATED/FAILED incidents and forge the audit actor
F-02	HIGH	Recovery (ESCALATED -> RETRYING) bypasses approval; CT-05 then dispatches	An approval-timeout incident can be dispatched without any approval
F-03	HIGH	CT-01 `/ops-events` has no authentication (sticky says "Authenticate")	Forged events, flooding, AI cost, Slack spam
F-04	HIGH	`errorWorkflow` set only on CT-06; CT-01 and CT-05 (named in CT-04's note) have none; CT-02/03/07/04 none	Main pipeline and watchdog failures may go unalerted (verify live instance)
F-05	HIGH	CT-02 trusts caller `previous_state`; update filters only on `id`; audit insert after update is not atomic	Races (stale scan vs live run) can overwrite states or lose audit rows
F-06	HIGH	CT-04 links errors via `incidents.execution_id` = CT-01's id only	CT-05/CT-06 errors never mark an incident FAILED
F-07	MEDIUM	CT-02 -> CT-07 node disabled	HubSpot outcome notes never created; docs/notes claim otherwise
F-	MEDIUM	CRITICAL accepted by validation/scoring but	AI text for CRITICAL events is